Assignment: MITRE ATLAS

Case study: HireWise AI

HireWise is a company that uses an AI-powered recruitment system to screen CVs, rank applicants, and recommend candidates to HR staff. The system uses a large language model (LLM) to summarize CVs and generate candidate suitability scores.

Recently, the security team discovered suspicious activity involving the system.

Incident report

Incident 1 — Manipulated CVs

The HR team received several applications containing unusual instructions hidden in the CV text. When processed by HireWise, some of these CVs caused the AI assistant to ignore its normal instructions and produce unrelated text in its candidate summaries.

Incident 2 — Unauthorized information exposure

During testing, an HR employee asked the AI assistant to summarize a candidate's application. The assistant included internal notes about the candidate that were not supposed to appear in the summary. Investigators found that the notes were stored in the system's internal document database.

Incident 3 — Repeated API queries

Security logs showed that an employee account submitted hundreds of slightly modified prompts to the AI system. The prompts asked for candidate rankings, scoring explanations, and examples of the model's responses. The account saved the outputs in local files.

Incident 4 — A suspicious external model

Investigators discovered a personal project repository belonging to the employee. It contained the collected AI outputs and a script that used them to fine-tune a smaller language model. The project description stated that the goal was to reproduce HireWise's candidate-ranking behavior.

Incident 5 — Possible training-data manipulation

The HR team also discovered that several CVs had been deliberately modified before being uploaded. Some contained misleading qualifications and instructions intended to influence the AI's ranking. However, investigators found no evidence that HireWise's underlying training dataset or model parameters had been modified.

Incident 6 — Unconfirmed impact

The smaller model was shared with other users. Investigators confirmed that it had been trained using outputs from HireWise, but they could not establish whether it reproduced the original model's capabilities, exposed additional confidential information, or was used for further attacks.

Student tasks

1. Use the official MITRE ATLAS matrix to identify relevant tactics and techniques for each incident.
2. Create your own layer in MITRE ATT&CK Navigator, selecting the ATLAS matrix.
3. Color your techniques:
    - Green: directly supported by the evidence.
    - Orange: implied or suspected, but not conclusively established.
4. Add a comment to every selected technique containing the incident number, supporting evidence, and justification.
5. Export your layer as a JSON file and submit a screenshot of the completed map.
6. Write a short report explaining the attack chain, what is confirmed, what remains uncertain, and three recommended defenses.